

The Five Legal Documents

SLA, NDA, SOW, MSA & Permission to Attack — Full Explanation With Examples

Prepared for: Muhammad Shafiq Goraya

Track: Red Team / Penetration Testing

Style: Plain explanations, real-world examples, no quiz format

Covers: The five core legal documents every penetration tester must understand, how they connect, and a real-world engagement scenario tying them all together

SLA

NDA

SOW

MSA

Permission to Attack

Third-Party Authorization

Scope Control

WHAT'S INSIDE

- Lesson 1 — Why are legal documents important in penetration testing?
- Quick Recap — SLA and NDA
- Lesson 6 — Statement of Work (SOW)
- Lesson 7 — Master Service Agreement (MSA)
- Lesson 8 — Permission to Attack
- Final Review — how all five documents connect
- Real-World Scenario — a bank engagement from start to finish
- Thinking Exercise — mid-engagement scope change

Lesson 1 · Why Are Legal Documents Important?

What Most Beginners Think

A Common (Wrong) Assumption

"I know hacking. I know Nmap. I know Metasploit. Now I can become a penetration tester." This is wrong. A professional penetration tester does much more than hacking. Before touching a client's computer, there are many legal documents that must be completed.

Real-Life Example

Imagine you are a plumber. A customer says: "Please fix my water pipe." Before starting, you may discuss what will be repaired, how much it will cost, who will pay, and what happens if something breaks. Only after both people agree do you start working.

A penetration tester works the same way. Before hacking a company's systems, both sides agree on: what systems can be tested, what cannot be tested, how long testing will last, what happens if something goes wrong, and who is responsible. Only then does the penetration test begin.

Why is This Important?

Imagine you scan Google's servers without permission. Even if you only wanted to "learn," the law may see it as an unauthorized attack. Now imagine Google hired you and you have signed legal documents — now your scanning is authorized because you have permission. That is the biggest difference between a hacker and a professional penetration tester.

Main Idea — The Real Order of Work

Planning

Legal Documents

Permission

Testing

Report

Not: Open Kali Linux → Hack. That is what beginners imagine — it is not how professionals actually work.

Many beginners think penetration testing is only about tools like Nmap, Burp Suite, Metasploit, and SQLMap. But in reality, a lot of the work is reading documents, signing agreements, understanding legal responsibilities, and working with clients as a business.

CompTIA PenTest+ Exam Tip

A penetration tester must have legal authorization before performing any testing. This is one of the most important concepts in PenTest+.

Quick Notes — Professional Pentesting Equals

- Technical skills
- Legal permission
- Business agreements
- Client trust

Key Takeaway

A penetration tester cannot start testing immediately just because they've learned hacking tools — legal permission and the right documents must be completed first. This single idea is the foundation for everything else in this lesson set.

Quick Recap · SLA and NDA

Before reaching the Statement of Work, two earlier documents set the foundation for any penetration testing engagement.

SLA — Service Level Agreement

An SLA is a general agreement that defines the services being offered and the responsibilities of each party — think of it as the overall expectations both sides agree to, before the finer details are worked out. It answers the question: **"What services are promised?"**

NDA — Non-Disclosure Agreement

An NDA exists to keep confidential information secret and prevent unauthorized disclosure. During a penetration test, you may see passwords, customer records, internal emails, and security weaknesses — the NDA legally binds everyone involved to keep that information private. It answers the question: **"How do we keep secrets safe?"**

Easy Memory Trick

SLA = Rules for the relationship. NDA = Keep secrets.

Lesson 6 · Statement of Work (SOW)

Full Form

SOW = Statement of Work

What is a Statement of Work?

An SOW is a detailed document that explains exactly what work will be done during the penetration test. Think of it as the detailed plan for the project.

Easy Example

Imagine you hire a builder to build a room. The agreement says: build one bedroom, size 12 x 12 feet, finish in 15 days, cost \$2,000. This detailed plan is exactly like an SOW — specific, measurable, and time-bound.

In Penetration Testing

Suppose a company hires you. The SOW may say:

- **Test:** Web Application, Internal Network, Wi-Fi
- **Do NOT Test:** Production Database, Payroll Server

It also includes the start date, end date, cost, deliverables (final report), and the scope of testing.

SLA vs SOW

SLA	SOW
General agreement	Detailed work plan
Defines services and responsibilities	Defines exactly what work will be done
Overall expectations	Specific tasks, scope, timeline, and deliverables

Easy Memory Trick

SLA = Rules. SOW = Work Details.

Why is an SOW Important?

Real Scenario

Imagine the client says: "Please also test our cloud servers." You reply: "That is not listed in the SOW." Now you have proof of what both parties agreed to. The instructor even calls it a "cover yourself" document, because it protects both the client and the penetration tester if there is a disagreement.

What Does an SOW Usually Include?

- Scope of work
- Timeline
- Cost / Billing
- Deliverables (what you will provide)
- Disclaimers or limitations
- Signatures of all parties

CompTIA PenTest+ Exam Tip

An SOW describes the detailed tasks, scope, timeline, and deliverables of a penetration testing engagement.

Lesson 7 · Master Service Agreement (MSA)

Full Form

MSA = Master Service Agreement

What is an MSA?

Many students get confused because SLA, SOW, and MSA all look similar. But they fit together in a clear structure — the MSA is the biggest and most general agreement between the client and the penetration testing company, and both the SLA and SOW can sit underneath it.

MSA (Big Agreement)

SLA (Service Rules)

SOW (Specific Work)

Easy Example

Imagine a company hires your penetration testing company every year. Instead of writing a brand-new legal contract every time, they create one Master Service Agreement. Later, for each new project, they just write a small SOW and refer back to the MSA. This saves time.

What Does an MSA Include?

- Payment terms
- Delivery requirements
- Confidentiality
- Intellectual Property (IP) rights
- Dispute resolution
- General terms and definitions
- Conditions that apply to future projects

Why is an MSA Useful?

Example for Understanding

Imagine a company hires you 10 times. Without an MSA, you must rewrite all the legal rules 10 times. With an MSA, you write the big agreement once, and then each new penetration test only needs a new Statement of Work. This saves time and keeps everything consistent.

Easy Memory Trick — Building a House

MSA = House Rules (e.g. no smoking, payment every month, guests must sign in) — these rules stay the same.

SOW = Today's Job (e.g. paint the kitchen, repair the roof, install new windows) — each job has its own SOW.

SLA vs SOW vs MSA

Document	Purpose
MSA	Overall legal agreement for the business relationship
SLA	Defines services and responsibilities
SOW	Defines the detailed work for one project

CompTIA PenTest+ Exam Tip

An MSA is the master agreement that contains the general legal terms and conditions for current and future engagements.

Lesson 8 · Permission to Attack

This is probably the most important document for a penetration tester — sometimes jokingly called a **"Get Out of Jail Free Card."**

What is Permission to Attack?

It is a written legal document that gives you official permission to perform penetration testing. Without it, you are not an authorized penetration tester — no matter what other agreements exist.

Easy Example

Imagine you enter someone's house at night. Without permission, the police may arrest you. Now imagine the owner gives you a signed letter saying: "I hired Muhammad Shafiq to inspect my house." If someone calls the police, you can show the letter — you have permission. The same idea applies to penetration testing.

In Penetration Testing

Suppose a company hires you. Before running a tool like Nmap or Metasploit, you must already have written authorization and proper signatures in place. Only then can you legally begin testing.

Why is This So Important?

During testing, someone may notice your scans. Security staff may think you are a hacker. Law enforcement may even become involved. If that happens, you need proof that you are an authorized penetration tester — without that proof, you could face real legal problems, even if your client secretly knew about the test.

Third-Party Permission

This is one of the most important exam points. Imagine your client uses AWS, Azure, or Google Cloud. The client owns the virtual machines, but they do not own the physical servers — those belong to the cloud provider. Sometimes you must also get authorization from the third-party provider before testing, in addition to your client's permission.

Who Can Perform the Test?

The Permission to Attack document also defines exactly who is authorized to perform the testing.

Example

Your company authorizes Muhammad and Ali to perform the test. Your friend Ahmed is not listed. If you ask Ahmed to run an Nmap scan for you, that is unauthorized, because his name is not included in the authorization document — even though he works alongside you.

What Does Permission to Attack Usually Include?

- Authorized testers
- Authorized systems
- Systems that must not be tested
- Testing time period
- Proper signatures
- Third-party authorization (if required)

CompTIA PenTest+ Exam Tip

Never begin a penetration test without written authorization (Permission to Attack). This is one of the highest-priority legal concepts in PenTest+.

Final Review · How the Five Documents Fit Together

Document	Purpose	Easy Memory
SLA	Defines services and responsibilities	What services are promised?
NDA	Protects confidential information	Keep secrets.
SOW	Explains the detailed work	What exactly will be done?
MSA	Overall agreement for long-term business	Master agreement.
Permission to Attack	Gives legal authorization to test	You can start testing now.

Real-World Scenario — A Bank Engagement

Imagine you own a penetration testing company, and a bank hires you. Here is how the five documents come together in order:

Step 1 — Sign the MSA. This creates the long-term business relationship between your company and the bank.

Step 2 — Create the SOW. It says: test the web application, test the internal network, finish in 5 days, deliver one final report.

Step 3 — Sign the SLA. It explains your responsibilities, the bank's responsibilities, and service expectations.

Step 4 — Both parties sign the NDA. Nobody can share passwords, customer data, security weaknesses, or internal company information.

Step 5 — The bank signs the Permission to Attack. Now you can legally begin the penetration test.

MSA
SLA
SOW
NDA
Permission to Attack
Start Penetration Test

This is an easy way to remember how the documents fit together.

Thinking Exercise · A Mid-Engagement Scope Change

The Situation

A company hires you to perform a penetration test. Halfway through the engagement, the client asks: "Can you also test our cloud servers?" However, the cloud servers were not included in the Statement of Work (SOW).

What Should You Do, and Why?

You should not simply start testing the cloud servers, even though the same client is asking. The correct response is to pause and treat this as a formal scope change, not an informal favor:

- **Explain the limitation:** Politely tell the client that the cloud servers are outside the current SOW, so testing them right now would be outside your authorized scope.
- **Check the Permission to Attack:** Even if the SOW were updated, the cloud servers would also need to be explicitly listed as authorized systems in the Permission to Attack document.
- **Check for third-party ownership:** If those cloud servers sit on AWS, Azure, or Google Cloud, the physical infrastructure belongs to the cloud provider, not the client. You may need separate authorization from that third-party provider before any testing can happen.
- **Update the paperwork first:** The client should sign an updated or additional SOW (and updated Permission to Attack) that formally includes the cloud servers before you touch them.
- **Only then proceed:** Once the new scope is documented and signed, and any third-party permissions are secured, you can legally test the cloud servers.

Why This Matters

This situation exists specifically because of everything covered in Lessons 6-8. The SOW protects you by proving what was originally agreed. The Permission to Attack protects you legally by proving who is authorized to test what. Skipping these steps — even for a client who trusts you and is asking nicely — would mean testing systems without proper authorization, which strips away your legal protection the moment something goes wrong.

The Full Keyword List

SLA

NDA

SOW

MSA

Permission to Attack

Scope

Deliverables

Third-Party Authorization

Confidentiality

Homework (10 minutes)

Without looking at your notes, explain these five topics in simple English, in your own words:

- The difference between an SLA and an SOW
- Why an MSA saves time for a company that hires the same pentest firm repeatedly
- Why Permission to Attack is called a "Get Out of Jail Free Card"
- Why cloud engagements sometimes need third-party authorization
- The correct order: MSA to SLA to SOW to NDA to Permission to Attack to Start Testing

If you can teach these five topics to someone else in simple English, you have truly understood them. Get some rest — you've earned it.